Vulnerability Assessment Report

25th July 2026

System Description

The server hardware consists of a powerful CPU processor and 128GB of memory. It runs on the latest version of Linux operating system and hosts a MySQL database management system. It is configured with a stable network connection using IPv4 addresses and interacts with other servers on the network. Security measures include SSL/TLS encrypted connections.

Scope

The scope of this vulnerability assessment relates to the current access controls of the system. The assessment covers a three-month period from May 2026 to July 2026. NIST SP 800-30 Rev. 1 is used to guide the risk analysis of the information system.

Purpose

The database server is a critical business system that stores and manages customer information used by employees for daily operations. Protecting this data is important because unauthorized access could expose sensitive information, disrupt business activities, and damage customer trust. If the server becomes unavailable, employees may not be able to access important information needed to perform their work. This assessment identifies security risks and recommends controls to protect the system.

Risk Assessment

Threat source	Threat event	Likelihood	Severity	Risk
External attacker	Gains unauthorized access to customer data	*3*	*3*	*9*
Cybercriminal	Launches a Denial-of-Service (DoS) attack to disrupt the server	*2*	*3*	*6*
Malicious insider	Modifies or deletes customer records without authorization	*2*	*3*	*6*

Approach

This assessment focused on threats that could affect the confidentiality, integrity, and availability of the database server. The selected threats were chosen because the database has been publicly accessible, making it a valuable target for attackers. The likelihood and severity scores were based on the possible impact on business operations and customer data. This approach helps prioritize the most significant security risks.

Remediation Strategy

The database server should no longer be publicly accessible and should only allow connections from authorized users. Multi-factor authentication (MFA), role-based access control (RBAC), and the principle of least privilege should be implemented to reduce unauthorized access. Data should be protected with TLS encryption, and the server should receive regular security updates and patches. System logs should be monitored continuously to detect and respond to suspicious activity quickly.